

Especificação de Requisitos

Plataforma Payproxy



Documento: Especificação de Requisitos

Versão: 1.0

Data: 21/07/2026

Status: Em elaboração

Contexto

A Secretaria Municipal da Fazenda de Salvador (SEFAZ) necessita contratar solução SaaS para operacionalizar a arrecadação municipal via DDA (Débito Direto Autorizado), com emissão de boletos registrados, split de pagamento entre múltiplos favorecidos e comunicação digital com contribuintes.

Este documento especifica os requisitos da plataforma intermediária que expõe uma API para geração de boletos com split, com suporte a **múltiplos parceiros bancários**, gestão de múltiplos tenants (aplicações consumidoras) e módulo de relatórios.

1. Requisitos Funcionais

1.1 Gestão de Acesso por Aplicação Consumidora

1.1.1 Ciclo de Vida da Aplicação

RF-AC-01 O sistema deve gerenciar o ciclo de vida de cada aplicação com os seguintes estados

explícitos: PENDENTE_APROVAÇÃO → ATIVA → SUSPensa → INATIVA .

RF-AC-02 O cadastro de nova aplicação deve passar por **aprovação explícita** de um administrador da plataforma antes de ter qualquer acesso liberado.

RF-AC-03 O administrador pode **suspender temporariamente** uma aplicação, bloqueando

todas as chamadas à API sem revogar configurações ou API keys. A reativação deve restaurar o estado anterior integralmente.

RF-AC-04 O administrador pode **inativar definitivamente** uma aplicação, encerrando todos os acessos. A inativação é irreversível sem novo ciclo de aprovação.

RF-AC-05 Toda mudança de estado deve registrar: administrador responsável, motivo (campo texto obrigatório) e timestamp.

RF-AC-06 Aplicação suspensa ou inativa deve receber resposta `403 Forbidden` com mensagem informativa em todas as chamadas à API, sem expor detalhes internos da restrição.

RF-AC-07 O sistema deve manter histórico completo e imutável de mudanças de estado por aplicação, consultável pelo backoffice.

1.1.2 Portal do Tenant — Múltiplos Usuários por Aplicação

RF-AC-08 A plataforma deve disponibilizar um **portal web por tenant**, separado do backoffice administrativo interno, onde os usuários da aplicação gerenciam boletos, configurações e relatórios.

RF-AC-09 Cada tenant pode ter **múltiplos usuários humanos** com papéis distintos:

Papel	Capacidades
ADMIN	Gerenciar usuários do tenant, configurar boleto e splits, visualizar relatórios e auditoria
OPERADOR	Emitir e cancelar boletos, consultar status, visualizar relatórios
VISUALIZADOR	Consulta de boletos e relatórios apenas (sem escrita)

RF-AC-10 O tenant ADMIN pode convidar, ativar e desativar usuários dentro do seu próprio tenant. O convite é enviado por e-mail e expira em 48 horas.

RF-AC-11 Cada usuário de tenant autentica com **e-mail + senha + 2FA** (TOTP) para acessar o portal.

RF-AC-12 Um usuário de tenant visualiza e gerencia **somente os dados do seu próprio tenant**
(isolamento estrito entre tenants).

RF-AC-13 Um tenant ADMIN **não pode conceder permissões além** do que o próprio tenant está autorizado pela plataforma (sem escalada de privilégios).

RF-AC-14 O sistema deve registrar na trilha de auditoria todas as ações de gestão de usuários
(convite, ativação, desativação, alteração de papel).

1.1.3 Permissões Granulares por API Key

RF-AC-15 Cada API key deve poder ter um **perfil de permissões granulares** além dos escopos

básicos, configurável pelo administrador da plataforma:

- Valor máximo por boleto (ex.: limitar a R\$ 50.000,00 por emissão)
- Limite diário de boletos emitidos
- Limite mensal de boletos emitidos
- Restrição por tipo de tributo (via campo `metadata`, ex.: somente IPTU e ISS)
- Permissão ou restrição de emissão em lote (batch)

RF-AC-16 O mesmo tenant pode ter **múltiplas API keys com perfis distintos** (ex.: chave de produção com acesso total, chave de integração com valor máximo reduzido e sem batch).

RF-AC-17 As permissões granulares podem ser **modificadas sem revogar a API key**, evitando interrupção operacional.

RF-AC-18 Tentativas de operação que excedam as permissões configuradas devem retornar `403 Forbidden` com mensagem que descreve o tipo de restrição violada, sem revelar os limites exatos configurados internamente.

RF-AC-19 O sistema deve alertar o administrador da plataforma quando uma aplicação atingir 80% do seu limite mensal de emissões.

1.1.4 Política de Senhas

RF-AC-20 Toda senha de usuário — tanto de operadores do backoffice (`BackofficeUser`) quanto de usuários de tenant (`TenantUser`) — deve atender **obrigatoriamente** aos seguintes critérios de complexidade no momento de criação ou alteração:

- Mínimo de **10 caracteres**
- Ao menos **uma letra maiúscula** (A–Z)
- Ao menos **uma letra minúscula** (a–z)
- Ao menos **um número** (0–9)
- Ao menos **um símbolo** (ex.: `!@#$%^&*()_+=[ ]{|};':",.<>?/`)

A violação de qualquer critério deve ser rejeitada com mensagem descritiva indicando o requisito não atendido. A validação deve ocorrer tanto no backend (Form Request) quanto com feedback visual em tempo real no frontend.

RF-AC-21 O sistema deve aplicar **controle de vencimento de senha** com as seguintes regras:

- Toda senha expira após **90 dias** a partir da data de última troca (`password_changed_at`).
- No primeiro login após o vencimento, o usuário é **redirecionado obrigatoriamente** para a tela

de troca de senha antes de acessar qualquer funcionalidade — a sessão permanece bloqueada até a conclusão da troca.

- Usuários sem `password_changed_at` registrado (primeiro acesso após convite) são tratados como
senha expirada e devem trocar na primeira autenticação.
- A nova senha não pode ser idêntica à senha atual.
- Após a troca bem-sucedida, `password_changed_at` é atualizado e o acesso é liberado normalmente.

1.2 Gestão de Tenants (Aplicações Consumidoras)

RF-01 O sistema deve permitir o cadastro de tenants, representando cada aplicação ou sistema

externo que irá consumir a API de boletos.

RF-02 Cada tenant deve possuir: nome, documento (CNPJ), status (ativo / suspenso / inativo) e

data de cadastro.

RF-03 O sistema deve permitir a criação, listagem e revogação de API keys por tenant.

RF-04 Cada API key deve possuir escopos de permissão granulares:

- `boleto:write` — emitir e cancelar boletos
- `boleto:read` — consultar boletos
- `report:read` — acessar relatórios

RF-05 A API key completa deve ser exibida **uma única vez** no momento da criação; após isso,

somente o prefixo (primeiros caracteres) é visível para identificação.

RF-06 O sistema deve suportar data de expiração opcional por API key.

RF-07 Deve haver controle de rate limiting por API key, configurável por tenant.

1.3 Gestão de Parceiros Bancários

RF-PART-01 A plataforma deve suportar o cadastro e operação de **múltiplos parceiros bancários** (fintechs, bancos ou correspondentes bancários autorizados), sem limitação a um único provedor.

RF-PART-02 Cada parceiro bancário cadastrado deve conter:

- Nome e identificador único na plataforma
- Tipo: `FINTECH`, `BANCO` ou `CORRESPONDENTE_BANCÁRIO`
- Credenciais de integração com a API do parceiro (armazenadas com AES-256-GCM)
- Funcionalidades suportadas: split de pagamento, registro DDA, QR Code Pix, CNAB 240, CNAB 400
- Status: `ATIVO` / `INATIVO`

RF-PART-03 O administrador da plataforma pode ativar ou desativar um parceiro bancário sem necessidade de redeploy e sem impactar tenants que utilizam outros parceiros.

RF-PART-04 Cada tenant deve configurar qual parceiro bancário será utilizado para emissão de boletos. Um tenant pode ter configurações para múltiplos parceiros, com um **parceiro padrão** definido.

RF-PART-05 No momento da emissão de um boleto via API, o tenant pode informar opcionalmente o parceiro bancário a ser utilizado; caso não informado, o parceiro padrão do tenant é aplicado.

RF-PART-06 A plataforma deve validar, antes da emissão, se o parceiro bancário selecionado suporta as funcionalidades requeridas (split, DDA, Pix), retornando erro claro caso não suporte.

RF-PART-07 A integração com cada parceiro bancário deve ser encapsulada em um adaptador específico daquele parceiro, de forma que novos parceiros possam ser incorporados sem alteração na API exposta aos tenants.

RF-PART-08 O resultado da emissão (código de barras, linha digitável, QR Code Pix, confirmação DDA) deve ser normalizado pela plataforma em formato padrão, independentemente do parceiro bancário utilizado.

1.4 Configuração de Boleto por Tenant

RF-08 Cada tenant deve ter uma configuração de boleto contendo:

- Referência ao parceiro bancário ativo para o tenant (conforme RF-PART-04)
- Prazo padrão de vencimento (em dias)
- Percentual de multa após vencimento
- Percentual de juros ao mês
- Percentual ou valor de desconto para pagamento antecipado (opcional)
- Dias de antecedência para aplicação do desconto (opcional)
- Linhas de instrução exibidas no boleto (até 2 linhas)
- URL de webhook para notificação de pagamento ao tenant
- Segredo HMAC para assinatura dos webhooks enviados ao tenant

RF-09 Um tenant pode ter configurações para múltiplos parceiros bancários (ex.: parceiro A para produção, parceiro B para sandbox), com indicação de qual está ativo como padrão.

1.5 Configuração de Split de Pagamento

RF-10 Cada tenant deve poder cadastrar múltiplos favorecidos (beneficiários) de split, associados à sua configuração de boleto.

RF-11 Cada favorecido do split deve conter:

- Nome/rótulo identificador
- Identificador de credencial do favorecido no parceiro bancário
- Tipo de split: **percentual** (ex.: 85%) ou **valor fixo** (ex.: R\$ 10,00)
- Ordem de prioridade de aplicação

RF-12 O sistema deve validar que:

- A soma dos splits percentuais não ultrapassa 100%
- A soma dos splits de valor fixo não ultrapassa o valor total do boleto
- A configuração combinada (percentual + fixo) resulta em valor positivo para todos os favorecidos

RF-13 O conjunto de splits configurado é aplicado automaticamente a todos os boletos gerados

pelo tenant, salvo configuração específica por boleto.

RF-14 O snapshot exato dos splits aplicados deve ser registrado junto ao boleto no momento da emissão, garantindo rastreabilidade histórica mesmo que a configuração seja alterada posteriormente.

1.6 Geração de Boletos

RF-15 O sistema deve expor endpoint para geração individual de boleto, recebendo:

- Referência externa do tenant (identificador no sistema do cliente)
- Dados do pagador: nome, CPF/CNPJ, e-mail, telefone, endereço completo
- Valor do boleto
- Data de vencimento
- Metadados livres (campo JSON para dados adicionais do tenant, ex.: tipo de tributo, exercício fiscal, inscrição imobiliária)

RF-16 O sistema deve expor endpoint para geração em lote (batch), suportando até 500 boletos por requisição, processados de forma assíncrona.

RF-17 O tenant deve poder consultar o andamento de um processamento em lote, incluindo contagem de sucessos e falhas individuais.

RF-18 O boleto gerado deve conter:

- Código de barras padrão CNAB FEBRABAN
- Linha digitável
- QR Code Pix dinâmico
- URL do boleto em PDF
- Confirmação de registro DDA (quando aplicável)
- Splits aplicados com valor calculado por favorecido

RF-19 O sistema deve garantir idempotência: boleto com mesma referência externa e mesmo tenant retorna o boleto existente (se ainda válido) sem criar duplicata.

RF-20 O sistema deve suportar cancelamento de boleto, desde que ainda não liquidado.

1.7 DDA (Débito Direto Autorizado)

RF-21 O registro DDA deve ser realizado automaticamente no momento da emissão do boleto,

por meio da integração com o parceiro bancário ativo, para os pagadores cujo CPF/CNPJ esteja cadastrado no sistema DDA da FEBRABAN.

RF-22 O sistema deve registrar e expor a informação de se o boleto está ou não registrado no

DDA.

1.8 Comunicação com o Contribuinte

RF-MSG-01 Cada tenant deve configurar o **modelo de comunicação** aplicável, mapeado aos modelos de contratação do Termo de Referência:

Modelo	Canais	Equivalente TR
Modelo 1	E-mail	Bolepix + DDA + E-mail (Tabela 01 — R\$ 1,51/guia liquidada)
Modelo 2	E-mail + WhatsApp	Bolepix + DDA + E-mail + WhatsApp (Tabela 02 — R\$ 2,10/guia liquidada)

RF-MSG-02 Ao emitir um boleto, o sistema deve enviar automaticamente ao pagador:

- **E-mail** com PDF do boleto, linha digitável, QR Code Pix e instruções de pagamento (ambos os modelos)
- **Mensagem WhatsApp** com link do boleto e QR Code Pix (somente Modelo 2)
- **Nota sobre Carnê Digital DDA:** o e-mail deve incluir bloco informativo orientando o contribuinte a ativar o DDA no app do seu banco para receber futuros boletos automaticamente, sem necessidade de buscar o PDF. O texto do bloco é configurável por tenant. O Payproxy não controla nem consulta o status de adesão ao DDA do contribuinte — a ativação é feita inteiramente no app do banco.

RF-MSG-03 O endereço de e-mail e o número de telefone utilizados no envio são provenientes dos dados do pagador informados no momento da emissão (RF-15). Campos ausentes não impedem a emissão — apenas o canal correspondente é suprimido, com registro em log.

RF-MSG-04 O tenant deve poder configurar template de e-mail com logotipo, nome da entidade e texto personalizado. Templates de WhatsApp devem seguir o padrão HSM (Highly Structured Messages) aprovado pela Meta.

RF-MSG-05 O sistema deve registrar o status de entrega de cada comunicação vinculada ao boleto: **ENVIADO** , **ENTREGUE** , **FALHA** . Falha de entrega não impede nem reverte a emissão do boleto.

RF-MSG-06 O tenant ADMIN ou OPERADOR pode reenviar manualmente a comunicação para um boleto específico, desde que o boleto esteja com status **PENDENTE** .

1.9 Conciliação e Notificações de Pagamento

RF-23 O sistema deve receber notificações (webhooks) do parceiro bancário informando a liquidação de boletos.

RF-24 Ao receber notificação de pagamento, o sistema deve:

- Atualizar o status do boleto para "Pago"
- Registrar data/hora, valor pago e canal de pagamento
- Invalidar imediatamente quaisquer outras formas de pagamento vinculadas ao mesmo documento (prevenção de duplicidade)

RF-25 O sistema deve retransmitir a notificação de pagamento para a URL de webhook cadastrada pelo tenant, assinada com HMAC-SHA256 usando o segredo configurado.

RF-26 A conciliação deve ser idempotente: notificações duplicadas para boleto já liquidado devem ser ignoradas sem gerar inconsistência.

RF-27 Falhas na entrega do webhook ao tenant devem gerar retentativas automáticas com

backoff exponencial (mínimo 3 tentativas).

RF-28 Um job periódico diário deve identificar boletos com vencimento ultrapassado e status

pendente, atualizá-los para "Expirado" após confirmar o status no parceiro bancário.

RF-29 O sistema deve executar um **job noturno de conciliação ativa** que identifica boletos

com status Pendente que não receberam notificação de pagamento via webhook e consulta proativamente o parceiro bancário ativo de cada boleto para verificar a situação real. O job deve:

- Selecionar boletos com status **PENDENTE** cujo vencimento esteja dentro de uma janela configurável (ex.: últimos 30 dias) e que não possuam registro de webhook de pagamento recebido do parceiro bancário
- Para cada boleto selecionado, consultar a API do parceiro bancário para obter o status atual
- Caso o boleto esteja **pago** no parceiro bancário:
 - Atualizar o status para **PAGO** na base de dados, registrando data/hora, valor e canal de pagamento retornados pelo parceiro bancário - Gerar registro de auditoria indicando que a atualização foi realizada pelo job de conciliação (ator: **SYSTEM/reconciliation-job**), e não por webhook recebido - Acionar a notificação webhook do tenant (conforme RF-25), informando o pagamento com os mesmos dados que seriam enviados em caso de notificação normal
- Caso o boleto esteja cancelado ou expirado no parceiro bancário, atualizar o status correspondente

sem acionar webhook de pagamento

- Processar os boletos em lotes configuráveis para não sobrecarregar a API do parceiro bancário nem gerar picos de requisições
- Ser **idempotente**: execuções repetidas não devem gerar duplicidade de notificações nem

inconsistências na base de dados

- Registrar ao final de cada execução: total de boletos consultados, total atualizados como pagos, total com outros status, total de erros de consulta
- Falhas individuais de consulta ao parceiro bancário devem ser registradas em log e não devem

interromper o processamento dos demais boletos da mesma execução

- O horário e a janela de busca devem ser configuráveis sem necessidade de redeploy

1.10 Relatórios

RF-44 O sistema deve fornecer relatório de sumário com os seguintes indicadores, filtráveis por

período:

- Total de boletos emitidos
- Total de boletos liquidados
- Total de boletos cancelados
- Total de boletos expirados
- Volume financeiro emitido
- Volume financeiro liquidado
- Taxa de liquidação (%)
- Ticket médio

RF-45 O sistema deve fornecer relatório de evolução temporal (diária, semanal ou mensal) cruzando emissão e liquidação.

RF-46 O sistema deve fornecer relatório de liquidações por canal de pagamento:

- PIX
- Internet Banking / Autoatendimento
- DDA
- Correspondente Bancário
- Guichê de Caixa
- Débito Automático em Conta

RF-47 O sistema deve fornecer relatório de liquidações segmentado por campos presentes nos

metadados do boleto (ex.: tipo de tributo, exercício, região administrativa, bairro, zona fiscal).

RF-48 O sistema deve fornecer relatório de inadimplência, identificando boletos vencidos há

mais de 30, 60 e 90 dias.

RF-49 O sistema deve permitir exportação dos dados de boletos em formato CSV e JSON, suportando filtros por período, status, canal e campos de metadados.

RF-50 Para exportações de grande volume, o processamento deve ser assíncrono, com disponibilização de URL de download após conclusão.

1.11 Painel Administrativo (Backoffice)

RF-36 O sistema deve possuir painel web administrativo para gestão da plataforma, com acesso restrito a operadores internos.

RF-37 O painel deve oferecer:

- Gestão de tenants (criação, edição, suspensão)
- Gestão de API keys por tenant
- Configuração de boleto e splits por tenant
- Configuração de credenciais do parceiro bancário por tenant
- Visualização de boletos com filtros avançados
- Dashboards com os relatórios RF-44 ao RF-48
- Visualização da trilha de auditoria

RF-38 O dashboard deve exibir visualmente, com atualização em tempo real:

- Gráfico de linha de emissão vs. liquidação por período
- Gráfico de distribuição por canal de pagamento
- Gráfico de distribuição por tipo de tributo (via metadados)
- Indicadores de SLA de disponibilidade

1.12 Trilha de Auditoria

RF-39 Toda operação de escrita (criação, alteração, cancelamento de boletos; criação e

revogação de API keys; alteração de configurações) deve gerar registro imutável de auditoria contendo: ator, ação, recurso afetado, timestamp, IP de origem e dados relevantes da operação.

RF-40 A trilha de auditoria deve ter retenção mínima de 5 anos.

RF-41 Operadores do backoffice devem poder consultar a trilha de auditoria com filtros por
tenant, tipo de operação, ator e período.

1.13 Higienização de Dados Cadastrais

RF-42 O sistema deve validar os dados cadastrais do pagador no momento da emissão do boleto:

- **CPF:** verificação de formato e dígitos verificadores (algoritmo Receita Federal)
- **CNPJ:** verificação de formato e dígitos verificadores
- **CEP:** validação de existência e preenchimento automático de logradouro, bairro, cidade e UF

RF-43 O sistema deve padronizar os dados de endereço do pagador conforme normas dos Correios (abreviatura de logradouro, formatação de CEP, capitalização), registrando o valor original e o valor padronizado junto ao boleto.

1.14 Importação de Arquivos

RF-IMP-01 O sistema deve aceitar importação de arquivos de lançamentos para emissão em massa de boletos via `POST /api/v1/imports` (multipart/form-data), com autenticação por API Key com escopo `boleto:write`.

RF-IMP-02 Formatos de arquivo suportados:

- CSV (delimitado por vírgula, ponto e vírgula ou tabulação — detectado automaticamente)
- TXT posicional (layout fixo, definido por mapping configurável por tenant)
- XML (estrutura padrão Payproxy)
- XLS/XLSX (planilha Excel)

RF-IMP-03 Encodings aceitos: UTF-8 e ISO-8859-1 (Latin-1), detectados automaticamente — necessário para sistemas legados municipais.

RF-IMP-04 Campos por linha/registro:

- **Obrigatórios:** CPF/CNPJ do pagador, nome, valor (R\$), data de vencimento, referência externa do tenant
- **Opcionais:** e-mail, telefone, endereço completo, metadados JSON (tipo de tributo, exercício fiscal, inscrição imobiliária)

RF-IMP-05 Validações aplicadas linha a linha:

- CPF/CNPJ: formato e dígitos verificadores (algoritmo Receita Federal)
- Valor: positivo, dentro do limite máximo configurado por tenant
- Vencimento: data válida no formato DD/MM/AAAA ou MM/DD/YYYY
- Referência externa: única por tenant (conforme RN-01)
- E-mail e CEP: formato válido, quando presentes

RF-IMP-06 O processamento é assíncrono. Ao receber o arquivo, o sistema retorna imediatamente o `import_id` com status `RECEBIDO`. O processamento ocorre em fila background.

RF-IMP-07 Ciclo de status do lote: `RECEBIDO` → `EM_PROCESSAMENTO` → `CONCLUIDO` (caminho normal) | `EM_PROCESSAMENTO` → `ERRO_CRITICO` (arquivo ilegível ou sem nenhuma linha válida).

RF-IMP-08 `GET /api/v1/imports/{id}` retorna: status atual, total de linhas do arquivo, aceitas, rejeitadas, boletos emitidos com sucesso, boletos com falha de emissão, percentuais correspondentes e timestamps de início e conclusão.

RF-IMP-09 `GET /api/v1/imports/{id}/rejects` disponibiliza arquivo de retorno para download com as linhas rejeitadas, código de erro e descrição do motivo, no mesmo formato do arquivo enviado (quando possível).

RF-IMP-10 Cada linha aceita na validação gera um job individual de emissão de boleto (`IssueBoletoFromImportJob`), processado de forma assíncrona e independente via fila. Falha na emissão — incluindo falha temporária na API do parceiro bancário — usa o mecanismo de retry nativo do Laravel (até 3 tentativas com backoff exponencial), sem afetar o processamento das demais linhas. Após esgotar as tentativas, a linha é marcada como `FALHA_EMISSAO` com o motivo registrado. A emissão de cada boleto aceito chama individualmente a API do parceiro bancário (`POST /recebimentos/{credencial}/transacoes` no caso do PJBank) — não há endpoint de lote no parceiro; o volume é gerenciado inteiramente pelo Payproxy via filas.

RF-IMP-11 Idempotência por arquivo: arquivo com hash SHA-256 idêntico a um já processado com sucesso é recusado com mensagem informativa, sem reproprocessamento.

RF-IMP-12 Ao concluir o processamento, o sistema envia notificação webhook ao tenant (quando configurado) com o resumo do lote: total aceitos, total rejeitados, total emitidos, total com falha de emissão.

RF-IMP-13 Limites por arquivo: máximo de 10 MB e 10.000 linhas por importação.

RF-IMP-14 `GET /api/v1/imports` lista o histórico de importações do tenant com filtros por status e período.

RF-IMP-15 O processamento de linhas deve respeitar o rate limit do parceiro bancário. O número máximo de jobs de emissão simultâneos por tenant é configurável via `config/imports.php` (padrão: 10 jobs concorrentes), impedindo rajadas que possam resultar em bloqueio pela API do parceiro.

1.15 Régua de Cobrança Ativa

RF-COB-01 O sistema deve permitir configuração de régua de cobrança ativa por tenant, definindo a sequência de notificações automáticas enviadas a pagadores de boletos pendentes em intervalos configuráveis antes e após o vencimento.

RF-COB-02 Cada regra da régua deve especificar: número de dias em relação ao vencimento (negativo = antes, positivo = depois), canal de envio (e-mail, WhatsApp ou ambos), tipo de mensagem (lembrete pré-vencimento / alerta de vencimento / cobrança pós-vencimento) e estado ativo/inativo individualmente.

RF-COB-03 Configuração padrão sugerida pela plataforma, personalizável por tenant:

Dia	Canal	Tipo
D-5	E-mail	Lembrete antecipado
D-1	E-mail + WhatsApp	Lembrete urgente
D+1	E-mail	Aviso de vencimento
D+7	E-mail + WhatsApp	Cobrança
D+30	E-mail	Cobrança final

RF-COB-04 A régua é executada por job diário que identifica boletos com status **PENDENTE** enquadrados na janela de cada regra ativa e dispara as notificações configuradas.

RF-COB-05 Cada notificação enviada pela régua é registrada em **boleto_notifications** com vínculo ao boleto e à regra aplicada, impedindo reenvio duplicado da mesma regra para o mesmo boleto no mesmo dia.

RF-COB-06 Boletos com status diferente de **PENDENTE** são excluídos automaticamente do processamento da régua.

RF-COB-07 O tenant pode ativar e desativar a régua globalmente e por regra individual no portal do tenant, sem necessidade de suporte técnico.

RF-COB-08 O tenant pode excluir boletos específicos da régua via campo **opt_out_cobranca**, definível no momento da emissão via API ou posteriormente no portal.

RF-COB-09 As notificações enviadas pela régua respeitam o modelo de comunicação configurado no tenant (RF-MSG-01): Modelo 1 envia apenas e-mail; Modelo 2 envia e-mail e WhatsApp.

RF-COB-10 O sistema registra métricas de eficácia da régua: percentual de boletos pagos após cada intervalo de notificação, disponível para análise por tenant no backoffice.

1.16 Portal Público do Contribuinte

RF-CONT-01 A plataforma disponibiliza portal público acessível ao cidadão/contribuinte, sem necessidade de login cadastrado, onde é possível consultar débitos pendentes, emitir 2ª via de boletos e acompanhar o status de pagamentos.

RF-CONT-02 O acesso é autenticado por CPF, com envio de link temporário por e-mail (token de uso único, validade de 24 horas). Não é permitido acesso sem autenticação por token.

RF-CONT-03 O CPF é tratado exclusivamente como hash SHA-256 — nunca armazenado em texto claro em nenhuma tabela do sistema (conformidade LGPD).

RF-CONT-04 O contribuinte autenticado visualiza todos os seus boletos associados, agrupados por município (tenant), exibindo: nome do município, tipo de tributo (via metadados), exercício fiscal, valor original, data de vencimento, status e ação disponível por boleto.

RF-CONT-05 O contribuinte pode solicitar 2ª via de boleto pendente ou vencido diretamente no portal. A 2ª via emite um **novo boleto** no parceiro bancário com vencimento atualizado (configurável por tenant: manter data original ou acrescentar N dias), mantendo vínculo com o boleto de origem via `parent_boleto_id`. O sistema armazena o histórico completo de todos os boletos gerados para um mesmo débito — o contribuinte visualiza a cadeia de emissões no portal. O `external_ref` da 2ª via é derivado do original (ex.: `{ref}-2via-1`, `{ref}-2via-2`) para garantir unicidade no parceiro bancário.

RF-CONT-06 Contribuinte com débitos em múltiplos municípios visualiza todos em uma única sessão autenticada, agrupados por município.

RF-CONT-07 O portal deve ser responsivo para dispositivos móveis.

RF-CONT-08 O contribuinte é identificado globalmente pelo `cpf_hash` (SHA-256) na entidade `contribuintes`. Um CPF com débitos em dois municípios diferentes corresponde ao mesmo registro de contribuinte na plataforma.

RF-CONT-09 O isolamento entre tenants é garantido via `boleto.tenant_id`: o contribuinte visualiza seus boletos de qualquer município, mas um tenant nunca acessa boletos de outro tenant.

RF-CONT-10 Na emissão de cada boleto via API (`POST /api/v1/boletos`), o sistema realiza automaticamente `firstOrCreate` do contribuinte pelo `cpf_hash`, vinculando o boleto ao contribuinte via `contribuinte_id`.

RF-CONT-11 Rotas públicas do portal:

GET /contribuinte	→ tela de entrada (CPF)
POST /contribuinte/verificar	→ envia link por e-mail (token 2
GET /contribuinte/debitos/{token}	→ lista de débitos agrupados por
POST /contribuinte/boleto/{id}/2via	→ emite 2ª via e redireciona par

RF-CONT-12 O portal exibe aviso de conformidade LGPD informando quais dados são utilizados e com qual finalidade.

1.17 Geointeligência

RF-GEO-01 A plataforma fornece relatório de geointeligência com mapa de calor de inadimplência por bairro, disponível no backoffice do tenant.

RF-GEO-02 GET /api/v1/reports/geo retorna dados no formato GeoJSON com os seguintes indicadores por bairro: total de boletos pendentes, pagos e vencidos, valor total em aberto (R\$) e taxa de inadimplência (%). O endpoint aceita filtros por período e status.

RF-GEO-03 Os dados de bairro são extraídos do campo `payer_address.bairro` (JSON já armazenado nos boletos). Bairros sem correspondência no GeoJSON do tenant são agrupados em categoria `Não identificado`.

RF-GEO-04 O backoffice exibe o mapa via componente interativo (Leaflet, open-source, sem API key externa), com polígonos dos bairros coloridos por intensidade de inadimplência — gradiente de verde (baixa) a vermelho (alta).

RF-GEO-05 Os polígonos geográficos de bairros são armazenados por tenant como arquivo GeoJSON estático, carregado no onboarding do município. O sistema não depende de API de mapas externa para funcionamento.

RF-GEO-06 O usuário pode clicar em um bairro no mapa para visualizar seus detalhes: quantidade de boletos por status, valor total, ticket médio e listagem dos boletos pendentes do bairro.

RF-GEO-07 O processamento do relatório geográfico é assíncrono para volumes elevados, seguindo o mesmo padrão de RF-50.

RF-GEO-08 Acesso ao relatório de geointeligência requer escopo `report:read` na API Key ou papel ADMIN/OPERADOR no portal do tenant.

1.18 Parcelamento e Carnê de Tributo

RF-PARC-01 O sistema deve suportar emissão de carnê de parcelamento — conjunto de boletos vinculados a um mesmo débito, com vencimentos e valores pré-calculados. O carnê é emitido via `POST /api/v1/boletos/carne`, recebendo:

- Referência do débito original (`external_ref`)
- Valor total do débito
- Número de parcelas (mínimo 2, máximo configurável por tenant)
- Data do primeiro vencimento
- Tipo de encargo: `SEM_JUROS`, `JUROS_SIMPLES` ou `JUROS_COMPOSTOS`
- Taxa de juros ao mês em percentual (obrigatório quando tipo $\neq$ `SEM_JUROS`)
- Percentual de desconto por cota única (opcional)
- Dados do pagador (nome, CPF/CNPJ, e-mail, telefone, endereço)
- Metadados livres (tipo de tributo, exercício fiscal, inscrição imobiliária)

RF-PARC-02 O sistema calcula automaticamente o valor de cada parcela antes da emissão:

- `SEM_JUROS` : valor total $\div$ número de parcelas (parcelas iguais)
- `JUROS_SIMPLES` : valor total $\times (1 + \text{taxa} \times \text{número de parcelas}) \div \text{número de parcelas}$
- `JUROS_COMPOSTOS` : valor total $\times [\text{taxa} \times (1 + \text{taxa})^n] \div [(1 + \text{taxa})^n - 1]$ (Tabela Price)
- Entrada diferenciada: quando informada, é descontada do valor total antes do cálculo das parcelas restantes
- Desconto por cota única: quando o contribuinte opta por pagar o valor total em um único boleto, o desconto configurado é aplicado sobre o valor total

RF-PARC-03 Cada parcela é emitida como boleto independente no parceiro bancário via `IssueBoletoFromImportJob`, com:

- `external_ref` derivado do original: `{ref}-parc-01`, `{ref}-parc-02`, ..., `{ref}-parc-N`
- Vencimento calculado: primeiro vencimento + (número da parcela – 1) mês
- Vinculação ao conjunto via `installment_plan_id` no banco de dados do Payproxy

O parceiro bancário (PJBank) não tem conhecimento do carnê — gerencia cada boleto de forma independente. A lógica de agrupamento, status consolidado e cancelamento em cascata é inteiramente responsabilidade do Payproxy.

RF-PARC-04 O pagamento de uma parcela não afeta as demais. O cancelamento do carnê cancela todas as parcelas com status `PENDENTE`, mantendo as já pagas com seus registros históricos.

RF-PARC-05 GET /api/v1/boletos/carne/{installment_plan_id} retorna o status consolidado do carnê:

- Total de parcelas, pagas, pendentes e vencidas
- Valor total do débito, valor pago e valor em aberto
- Lista de parcelas com status, vencimento e valor individual

RF-PARC-06 O contribuinte visualiza o carnê completo no portal público (RF-CONT), com status de cada parcela e opção de emitir 2ª via de parcela individual vencida ou pendente.

RF-PARC-07 O carnê pode ser gerado em massa via importação de arquivo (RF-IMP). Cada linha do arquivo representa um contribuinte e deve conter: número de parcelas, valor total, data do primeiro vencimento e tipo de encargo. O sistema gera os boletos de todas as parcelas de todos os contribuintes via fila de jobs, respeitando o limite de concorrência configurado (RF-IMP-15).

RF-PARC-08 Ao concluir a emissão do carnê, o sistema envia ao contribuinte por e-mail o resumo com: valor total, número de parcelas, calendário de vencimentos e link para o portal onde todos os boletos estão disponíveis para download.

1.19 App Nativo do Contribuinte

RF-APP-01

A plataforma deve disponibilizar aplicativo móvel nativo para iOS (13+) e Android (8+), desenvolvido em React Native. A entrega é faseada:

- **PoC:** distribuído via TestFlight (iOS) e APK side-loading (Android) para avaliadores — sem publicação nas lojas
- **Produção:** publicado na App Store e Google Play após validação da PoC

O app oferece ao contribuinte as mesmas funcionalidades do portal web (RF-CONT-01 a RF-CONT-12): autenticação por CPF via link por e-mail, consulta de débitos por município, emissão de 2ª via, acesso ao carnê de parcelas e histórico de pagamentos.

RF-APP-02

A autenticação segue o mesmo fluxo do portal web: contribuinte informa o CPF, recebe link por e-mail (token de uso único, validade 24h) e acessa o app. O app armazena o token de sessão de forma segura no keychain (iOS) / keystore (Android), com validade configurável (padrão: 7 dias), evitando reautenticação a cada abertura.

RF-APP-03

O app exibe todos os débitos do contribuinte agrupados por município, com: tipo de tributo, exercício, valor atualizado, data de vencimento, status (pendente, pago, vencido) e ação disponível por boleto (2ª via, ver carnê).

RF-APP-04

O app deve oferecer leitor de QR Code Pix via câmera do dispositivo, abrindo o aplicativo de pagamento do banco do contribuinte com os dados pré-preenchidos via deep link.

RF-APP-05

O app deve enviar notificações push ao contribuinte nas seguintes situações:

- Vencimento em 5 dias (D-5)
- Vencimento em 1 dia (D-1)
- Boleto vencido (D+1)
- Confirmação de pagamento recebido
- Nova 2ª via disponível

O contribuinte pode configurar quais notificações receber nas preferências do app. As notificações respeitam o opt-out configurado (RF-COB-08).

RF-APP-06

O contribuinte pode compartilhar o código de barras, linha digitável ou PDF do boleto diretamente do app para outros aplicativos (WhatsApp, e-mail, etc.) via mecanismo nativo de compartilhamento do sistema operacional.

RF-APP-07

O app deve armazenar em cache os últimos débitos consultados, permitindo visualização sem conexão à internet. Ações que requerem conexão (2ª via, pagamento) exibem mensagem informativa quando offline.

RF-APP-08

O app deve suportar autenticação biométrica (Face ID / Touch ID / impressão digital) como segundo fator opcional para abrir o app após a sessão inicial autenticada por e-mail.

RF-APP-09

O app deve solicitar apenas as permissões estritamente necessárias ao usuário: câmera (para leitura de QR Code) e notificações push. Nenhum dado pessoal é armazenado

permanentemente no dispositivo além do token de sessão — em conformidade com LGPD e políticas da App Store e Google Play.

1.20 Modelo de Dados Tributários

RF-TRIB-01

O campo `metadata` do boleto deve reconhecer e validar o tipo de tributo via `metadata.tipo_tributo`. Valores aceitos na PoC: `IPTU`, `ISS`, `TFF`, `TAXA`, `DIVIDA_ATIVA`, `OUTROS`. Valores fora dessa lista são rejeitados com erro `422`. Novos tipos podem ser incorporados sem alteração na API — a lista é configurável por versão da plataforma.

RF-TRIB-02

Campos obrigatórios em `metadata` por tipo de tributo, validados no momento da emissão:

Tipo	Campos obrigatórios
<code>IPTU</code>	<code>inscricao_imobiliaria</code> , <code>exercicio</code> , <code>parcela</code>
<code>ISS</code>	<code>inscricao_mobiliaria</code> , <code>competencia</code>
<code>TFF</code>	<code>inscricao_mobiliaria</code> , <code>exercicio</code>
<code>TAXA</code>	<code>exercicio</code> , <code>descricao_taxa</code>
<code>DIVIDA_ATIVA</code>	<code>exercicio</code> , <code>numero_cda</code> , <code>tipo_tributo_origem</code>
<code>OUTROS</code>	nenhum campo adicional obrigatório

RF-TRIB-03

Cada tenant pode configurar encargos específicos por tipo de tributo: percentual de multa, juros ao mês e desconto máximo permitido. Quando configurado por tipo, sobrepõe os encargos padrão do tenant (RF-08).

RF-TRIB-04

Os relatórios (RF-44 a RF-48), a régua de cobrança (RF-COB) e o mapa de geointeligência (RF-GEO) segmentam e filtram dados por `metadata.tipo_tributo` automaticamente.

1.21 Reporte de Inconsistência Cadastral

O Payproxy não é a fonte de verdade dos dados cadastrais do contribuinte — essa responsabilidade é do sistema tributário (GRP) da SEFAZ. Os dados chegam ao Payproxy via importação de lançamentos (RF-IMP). Portanto, o Payproxy atua exclusivamente como **canal de comunicação** para reportar inconsistências ao operador da SEFAZ, que realiza a correção no GRP. Na próxima importação, os dados corretos chegam automaticamente ao Payproxy.

RF-INC-01

O portal do contribuinte e o app devem oferecer formulário de reporte de inconsistência cadastral, permitindo ao contribuinte informar: campo com dado incorreto (nome, endereço, e-mail, telefone), descrição da inconsistência e upload opcional de documento comprobatório (JPG/PNG/PDF, máx. 5 MB).

RF-INC-02

O reporte gera um ticket no backoffice do tenant com status **PENDENTE**, exibindo: dados atuais no Payproxy, descrição da inconsistência informada pelo contribuinte e documento anexado. O Payproxy **não altera nenhum dado cadastral** — o ticket serve apenas para notificar o operador.

RF-INC-03

O operador da SEFAZ analisa o ticket no backoffice e executa uma das ações:

- **Encaminhar ao GRP:** marca o ticket como **ENCAMINHADO**, indicando que a correção foi realizada no sistema tributário. O contribuinte recebe e-mail confirmando que o reporte foi recebido e está sendo tratado.
- **Rejeitar:** marca como **REJEITADO** com motivo obrigatório. O contribuinte recebe e-mail com o motivo da rejeição.

RF-INC-04

Após a correção no GRP e a próxima importação de lançamentos, os dados atualizados chegam ao Payproxy automaticamente via RF-IMP. O Payproxy não realiza nenhuma sincronização ativa com o GRP.

RF-INC-05

Tickets sem resposta do operador após prazo configurável (padrão: 5 dias úteis) geram alerta no backoffice ao gestor do tenant.

1.22 CzRM — Jornada do Cidadão

RF-CRM-01 A plataforma deve disponibilizar timeline unificada da jornada do contribuinte, consolidando todos os eventos relacionados ao seu CPF em ordem cronológica decrescente.

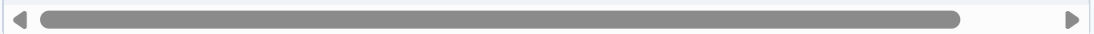
RF-CRM-02 Os eventos exibidos na timeline são construídos a partir das tabelas existentes, sem armazenamento adicional:

Evento	Origem
Boleto emitido	boletos
E-mail enviado	boleto_notifications
WhatsApp enviado	boleto_notifications
Boleto visualizado no portal	contribuinte_access_tokens
AR Digital lido / entregue / confirmado	ar_digital_events
Pagamento recebido	boletos (status PAGO)
2ª via solicitada	boletos (parent_boleto_id preenchido)

RF-CRM-03 No portal do contribuinte, a timeline é exibida como aba "Histórico" na sessão autenticada (GET /contribuinte/debitos/{token}), sem necessidade de novo login. O contribuinte visualiza apenas os eventos do seu próprio CPF no tenant correspondente ao link de acesso.

RF-CRM-04 No backoffice, a timeline é acessível via seção "Contribuintes":

GET /backoffice/contribuintes	→ busca por CPF (hash SHA-256 int
GET /backoffice/contribuintes/{cpf_hash}	→ timeline completa do contribuint



O operador visualiza todos os eventos do contribuinte dentro do seu tenant. A busca aceita CPF formatado ou não — o sistema calcula o hash internamente antes de consultar.

1.23 Segurança & Conformidade LGPD

1.23.1 Portal do Titular (Art. 18 LGPD)

RF-LGPD-01 A plataforma deve disponibilizar portal público do titular de dados, acessível pelo contribuinte para exercer seus direitos previstos no Art. 18 da LGPD, sem necessidade de cadastro prévio. Rotas públicas:

GET /titular/verificar	→ tela de verificação por CPF
POST /titular/verificar	→ envia link por e-mail (token 24h)
GET /titular/dados/{token}	→ exibe dados do titular
POST /titular/exportar/{token}	→ gera PDF com todos os dados associados
POST /titular/solicitar-exclusao/{token}	→ abre ticket de anonimização no backoffice

RF-LGPD-02 O acesso ao portal do titular é autenticado por CPF + link temporário enviado por e-mail (token de uso único, validade 24 horas), sem senha ou cadastro. O token é armazenado na tabela `titular_access_tokens` com `cpf_hash`, `expires_at` e `used_at`.

RF-LGPD-03 O portal do titular exibe todos os boletos associados ao CPF informado, agrupados por tenant (município), com: data de emissão, valor, status, tipo de tributo e canal de pagamento utilizado quando liquidado.

RF-LGPD-04 A solicitação de exclusão de dados gera ticket no backoffice com status `PENDENTE`. A exclusão é implementada como **anonimização** — nunca deleção — com aviso explícito ao titular de que dados fiscais são retidos por 5 anos conforme CTN Art. 195. O administrador executa a anonimização no backoffice após análise.

1.23.2 Mascaramento de Dados Pessoais

RF-LGPD-05 CPF, e-mail e telefone dos pagadores devem ser exibidos mascarados por padrão em todas as telas do backoffice e portal do tenant:

Dado	Formato mascarado
CPF	*.456.789-
E-mail	r***@dominio.com.br
Telefone	(79) *-2868

RF-LGPD-06 Usuários com papel `ADMIN` podem visualizar o dado completo clicando em "exibir". Cada visualização de dado completo registra entrada na trilha de

auditoria com: usuário, dado acessado, IP e timestamp.

1.23.3 Consentimento para WhatsApp

RF-LGPD-07 O envio de mensagens via WhatsApp deve ser condicionado à existência de consentimento rastreável registrado na tabela `whatsapp_consents`, com os campos: `tenant_id`, `cpf_hash` (SHA-256), `phone_hash` (SHA-256), `consented_at`, `consent_ip`, `revoked_at`, `revocation_ip`.

RF-LGPD-08 Toda mensagem WhatsApp enviada ao contribuinte deve incluir link de opt-out que registra a revogação do consentimento em `whatsapp_consents.revoked_at`. Após revogação, nenhuma mensagem WhatsApp deve ser enviada até novo consentimento explícito.

1.23.4 Retenção e Expurgo de Dados

RF-LGPD-09 O sistema deve executar rotina semanal de retenção de dados via command `php artisan data:retention`, com suporte a flag `--dry-run` para simulação sem alteração. A rotina aplica as seguintes políticas:

Dado	Retenção	Ação após prazo
Dados fiscais do boleto (valor, vencimento, referência, tributo)	5 anos (CTN Art. 195)	Manter — nunca anonimizar
Dados pessoais do pagador (nome, CPF, e-mail, telefone, endereço)	5 anos do vencimento	Anonimizar: substituir por <code>NULL</code>
Eventos AR Digital (e-mail, telefone)	5 anos	Anonimizar campos pessoais; manter carimbos RFC 3161
Trilha de auditoria (<code>audit_logs</code>)	2 anos	Exclusão definitiva
API Keys revogadas	90 dias após revogação	Exclusão definitiva

RF-LGPD-10 Cada execução da rotina de retenção registra em `audit_logs`: total de registros analisados, total anonimizados, total excluídos e eventuais erros.

1.23.5 Notificação de Incidente de Segurança (Art. 48 LGPD)

RF-LGPD-11 O backoffice deve disponibilizar tela de abertura de incidente de segurança com os campos: descrição, data de descoberta, categorias de dados afetados, estimativa de titulares impactados e medidas de contenção adotadas.

RF-LGPD-12 Ao abrir um incidente, o sistema exibe countdown de **72 horas** para notificação obrigatória à ANPD (Art. 48 LGPD), com registro de timeline: data de descoberta, data de contenção e data de notificação à ANPD.

1.23.6 Painel ROT/RIPD — Integração com Datum via LGPD Gateway

O sistema de gestão LGPD adotado pelos municípios parceiros na PoC é o **Datum** (plataforma de governança LGPD municipal). O **LGPD Gateway** — projeto Laravel independente mantido pela Ciberian — atua como middleware entre o Payproxy e o Datum instalado no servidor de cada prefeitura. O Gateway expõe uma API normalizada via Strategy Pattern: adicionar um novo município exige apenas uma nova Strategy no Gateway, sem nenhuma alteração no Payproxy.

RF-LGPD-13 O backoffice deve exibir, por tenant, o painel de governança LGPD consultado ao **LGPD Gateway** via `DatumService`, que por sua vez lê os dados diretamente do **Datum** do município. Painel acessível em `/backoffice/tenants/{tenant}/lgpd`. O painel exibe duas seções:

- **ROT — Registro de Operações de Tratamento:** lista de operações com operação, categorias de dados, finalidade, base legal e status de conformidade.
- **RIPD — Relatório de Impacto à Proteção de Dados:** lista de relatórios de impacto com título, operações avaliadas, nível de risco identificado e status (`Rascunho` / `Finalizado` / `Assinado`). O RIPD é exigido pelo Art. 38 LGPD para operações de alto risco — o Payproxy exibe o status mas nunca elabora o relatório, responsabilidade do DPO do tenant no Datum.

RF-LGPD-14 O painel ROT/RIPD é **somente leitura** no Payproxy. O cadastro e manutenção das operações de tratamento e dos relatórios de impacto é responsabilidade do DPO do tenant no **Datum**. O Payproxy nunca cadastra, edita ou exclui dados de ROT ou RIPD diretamente.

RF-LGPD-15 Tenant sem Datum conectado ao LGPD Gateway (`LGPD_GATEWAY_URL` não definido ou tenant sem Strategy configurada) exibe mensagem informativa no painel: *"Governança LGPD não configurada para este tenant."* — sem erro ou quebra de fluxo.

2. Requisitos Não Funcionais

2.1 Disponibilidade e Performance

RNF-01 A plataforma deve garantir disponibilidade mínima de **99,5%** mensal (SLA).

RNF-02 A geração de boleto individual deve responder em até **3 segundos** em condições normais de operação.

RNF-03 A plataforma deve suportar o volume estimado de **341.289 boletos/mês** (≈ 11.376 boletos/dia) com capacidade de pico superior.

RNF-04 O processamento em batch deve suportar 500 boletos por requisição de forma assíncrona.

RNF-05 Os relatórios de grandes períodos devem ser processados de forma assíncrona para não impactar a disponibilidade da API.

2.2 Segurança

RNF-06 Todas as credenciais de integração com parceiros bancários devem ser armazenadas criptografadas com AES-256-GCM; nunca em texto simples.

RNF-07 API keys devem ser armazenadas apenas como hash SHA-256; o valor completo não deve ser recuperável.

RNF-08 Toda comunicação deve ser feita sobre HTTPS/TLS 1.3 ou superior.

RNF-09 Webhooks recebidos dos parceiros bancários devem ter a assinatura HMAC-SHA256 validada antes de qualquer processamento.

RNF-10 Webhooks enviados ao tenant devem ser assinados com HMAC-SHA256 usando o

segredo configurado pelo tenant.

RNF-11 O acesso ao backoffice deve exigir autenticação multifator (2FA).

RNF-12 O backoffice deve implementar controle de acesso baseado em papéis (RBAC).

RNF-13 O sistema deve aplicar rate limiting por API key para prevenir abuso.

RNF-14 Todos os dados pessoais dos pagadores (CPF/CNPJ, e-mail, telefone, endereço) devem

ser tratados em conformidade com a LGPD (Lei nº 13.709/2018), com acesso controlado e registrado.

RNF-27 Todas as respostas HTTP da plataforma devem incluir os seguintes cabeçalhos de segurança: `Content-Security-Policy`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload`, `Referrer-Policy: strict-origin-when-cross-origin` e `Permissions-Policy: geolocation=(), microphone=(), camera=()`.

RNF-28 As rotas de login do backoffice e do portal do tenant devem aplicar rate limiting de **5 tentativas por IP a cada 15 minutos**. Após atingir o limite, a resposta deve informar o tempo restante para nova tentativa (`retry_after`). O rate limiting é independente do controle por API Key (RNF-13).

RNF-29 O sistema deve suportar configuração de **IP Allowlist por tenant**: campo `allowed_ips` (JSON, nullable) na tabela `tenants`. Quando preenchido, requisições à API originadas de IPs fora da lista são bloqueadas com HTTP 403 e registradas na trilha de auditoria. Quando vazio, o acesso é permitido de qualquer IP.

RNF-30 API Keys devem suportar data de expiração configurável (`expires_at`). Um job diário expira automaticamente as keys vencidas (status `expired`). Notificações por e-mail são enviadas ao tenant **15 dias e 7 dias** antes da expiração. Requisições com key expirada recebem HTTP 401 com mensagem informativa.

2.3 Conformidade e Interoperabilidade

RNF-15 Os boletos devem seguir o padrão CNAB FEBRABAN, com suporte explícito aos layouts **CNAB 240** e **CNAB 400** para liquidação e conciliação bancária.

RNF-16 A API deve seguir o padrão REST com autenticação via API Key.

RNF-17 Os formatos de troca de dados suportados devem incluir JSON.

RNF-18 Todos os dados do município/tenant devem ser armazenados exclusivamente em servidores localizados em território nacional, em conformidade com a LGPD.

RNF-19 A infraestrutura de hospedagem deve atender a padrões reconhecidos de segurança
(ISO 27001, ISO 22301, Tier III ou equivalentes).

RNF-20 Os dados devem ser exportáveis em formatos abertos (CSV, JSON) para garantir portabilidade e independência tecnológica. Ao encerramento do contrato, todos os dados do município devem ser disponibilizados para exportação completa sem ônus adicionais e eliminados dos sistemas da plataforma após confirmação de recebimento pelo contratante.

RNF-25 Todos os endpoints da API REST devem ser documentados sob o padrão **OpenAPI/Swagger**, com a especificação mantida atualizada e disponível publicamente para as aplicações consumidoras.

2.4 Manutenibilidade e Operação

RNF-21 A plataforma deve ser disponibilizada como SaaS (Software as a Service), sem necessidade de instalação local pelos clientes.

RNF-22 O sistema deve ter mecanismo de backup automatizado e redundância operacional.

RNF-23 O sistema deve expor endpoint de health check para monitoramento de disponibilidade.

RNF-24 Logs de erros e eventos de sistema devem ser centralizados e consultáveis pela equipe
de operação.

RNF-26 O suporte técnico à plataforma deve atender aos seguintes níveis de severidade (TR 4.1.27):

Severidade	Crterios de enquadramento	Tempo de resposta	Tempo de resoluo	Cobertura
Alta	Plataforma totalmente indisponvel, falha na comunicao DDA, falha no processo de liquidao	≤ 1 hora	≤ 4 horas	24x7
Mdia	Relatrios indisponveis, instabilidade intermitente, degradao de performance	≤ 4 horas	≤ 12 horas	Horrio comercial (8h-18h)
Baixa	Dvidas operacionais, ajustes de interface, extrao de dados	≤ 12 horas	≤ 24 horas	Horrio comercial (8h-18h)

2.5 Reteno de Dados

RNF-31 Os dados fiscais dos boletos — valor, data de vencimento, referncia externa, tipo de tributo, nosso nmero bancrio e splits aplicados — devem ser retidos por **mnimo de 5 anos** a partir da data de emisso, em conformidade com o CTN Art. 195, permanecendo legveis e consultveis pelo backoffice durante todo esse perodo. A anonimizao de dados pessoais do pagador (RF-LGPD-09) no deve afetar os campos de natureza fiscal.

3. Regras de Negcio

RN-01 Idempotncia na emisso : Boleto com mesma **referncia** e mesmo **tenant** j existente e vlido (status $\neq$ cancelado e $\neq$ expirado) no deve gerar novo boleto — o existente deve ser retornado.

RN-02 Validao de split no momento da emisso : Mesmo que a configurao de split tenha sido validada no cadastro, o sistema deve revalida-la no momento da gerao de cada boleto, garantindo que os valores calculados sejam consistentes com o valor do boleto.

RN-03 Cancelamento restrito : Boleto s pode ser cancelado quando estiver com status "Pendente". Boletos pagos ou expirados no podem ser cancelados.

RN-04 Imutabilidade da trilha de auditoria : Registros de auditoria não podem ser alterados

ou excluídos por nenhum ator, incluindo operadores administrativos.

RN-05 Remuneração por liquidação : A cobrança do serviço ao tenant deve ser baseada exclusivamente em boletos efetivamente liquidados, não em boletos emitidos.

RN-06 Snapshot de configuração : Os parâmetros de boleto (multa, juros, desconto, instruções) e os splits efetivamente aplicados devem ser gravados junto ao boleto no momento da emissão, de forma que alterações futuras na configuração não alterem boletos já emitidos.

RN-07 DDA e múltiplos meios de pagamento : Um mesmo boleto pode ser liquidado por qualquer canal disponível (código de barras, Pix, DDA). A liquidação por qualquer canal deve invalidar imediatamente os demais.

RN-08 Integridade dos splits : A soma dos valores calculados dos splits nunca deve ultrapassar o valor total do boleto. O valor residual (não distribuído via splits) permanece na conta principal do tenant.

RN-09 Prazo de repasse D+1 : Os valores arrecadados via liquidação de boletos devem ser repassados às contas dos beneficiários (tenant e favorecidos do split) até o próximo dia útil após a data de liquidação (D+1), em conformidade com TR 5.10.

4. Integrações Externas

Sistema	Finalidade	Sentido
Parceiro Bancário (ex.: PJBank, outros)	Emissão, registro, consulta e cancelamento de boletos; registro DDA; webhook de pagamento	Bidirecional
Sistema do Tenant (ERP/Tributário)	Consumo da API de boletos; recebimento de webhooks de pagamento	Bidirecional

Sistema	Finalidade	Sentido
FEBRABAN / Rede Bancária	Liquidação efetiva dos boletos pelos canais de pagamento	Indireto (via parceiro bancário)
OVC360 / Ouvimos	Envio de notificações WhatsApp via BSP Meta credenciado	Saída